

SUMMER INTERNSHIP PROGRAM REPORT ON CYBER SECURITY &
ETHICAL HACKING

At Maincrafts Technology

Submitted By

Abhishek Verma

PRN : 202301040047

DEPARTMENT OF COMPUTER ENGINEERING

MIT Academy of Engineering, Alandi(D)

Pune Maharashtra - 412105

Academic Year 2026-27

CERTIFICATE

This is to certify that the “**Summer Internship Program (SIP)**” report submitted by Abhishek Verma (**PRN 202301040047**) is work done by him and is submitted during 2026-27 academic year.

SIP Guide

Dr. Pramod Ganjewar

Department - Internship Coordinator

Mr. Nilesh Navghare
Mrs. Ambika Kalbandi

HOD

Department of Computer Engineering

(Dr. Pramod Ganjewar)

Department of Computer Engineering

MIT Academy of Engineering, Alandi(D)

Pune Maharashtra - 412105

INTERNSHIP BONAFIDE LETTER



INTERN I'D: MT6094

CERTIFICATE OF INTERNSHIP

This is presented to

Abhishek Verma

Has successfully completed an internship at Maincrafts Technology.

Cyber Security & Ethical Hacking

14 June 2026 to 29 July 2026

During the internship, Demonstrated dedication, professionalism, and a strong commitment to learning and contributing to projects.

We are highly appreciate the valuable effortsand extend our best wishes for a successful and rewarding professional career ahead.


Internship Head



Company Name: Maincrafts Technology

MSME No. UDYAM-UP-75-0096043

Website: www.maincrafts.com

Email: info.mainflow@gmail.com



ACKNOWLEDGEMENT

I, Abhishek Verma (PRN: 202301040047), would like to express my sincere gratitude to the Management, Director, and Dean of MIT Academy of Engineering, Pune, for emphasizing the significance of the Summer Internship Program and providing me with an opportunity to interact with industry professionals.

First and foremost, I would like to thank Maincrafts Technology for giving me the opportunity to undertake my internship in the Cyber Security & Ethical Hacking domain. I am also grateful to the entire team at Maincrafts Technology for their support, guidance, patience, and openness throughout my internship. Their encouragement and structured task-based learning approach helped create a positive and productive learning environment.

I would like to express my sincere thanks to the Head of the Department, the Internship Coordinator, and all the faculty members of the Department of Computer Engineering for their continuous support, guidance, and valuable advice throughout the internship process.

Finally, I am extremely grateful to all the faculty and staff members of the department, as well as my friends, for their valuable support, encouragement, and assistance in the successful completion of my internship.

Abhishek Verma

Table of Contents

Topic			Page No.
1.	Introduction		
	1.1	Abstract	7
	1.2	Description of Maincrafts Technology	7-9
	1.3	Introduction about workdone	10
	1.4	Introduction about Reporting Services Team	11-13
2.	Internship Discussion		
	2.1	Opportunity Description	14
	2.2	Role description/statement	14
	2.3	Scope	14-15
	2.4	Implementation Details	16-19
	2.5	Tools/Technologies used regularly	20-25
	2.6	Most challenging tasks performed	25-26
3.	Learning Outcomes		
	3.1	Technical Skills Acquired	27
	3.2	Managerial/Soft Skills Acquired	27-28

	3.3	Problem-Solving & Critical Thinking	28
4.	Conclusion & Future Scope		
	4.1	Conclusion	29
	4.2	Future Scope	29-30
5.	References		31

1. INTRODUCTION

1.1 Abstract of SIP

Abhishek Verma conducted a 6-week Summer Internship Programme on Cybersecurity and Ethical Hacking at Maincrafts Technology. The internship is purely online and consists of 4 deliverable based tasks, which increase in complexity in relation to each other. The programme covers the entire lifecycle of a vulnerability assessment engagement from setting up the initial lab environment and deployment of a target application, through reconnaissance and automated scanning for vulnerabilities, to manual web application security testing and professional documentation of the results in a Vulnerability Assessment Report (VAR).

The programme simulates the real-world work processes of cybersecurity professionals in enterprise environments in which each stage of a penetration testing/vulnerability assessment needs to be planned, conducted, documented and reported professionally. All hands-on activities were conducted within the confines of the individually set up personal cybersecurity lab environment. Throughout the duration of the internship, no real-world infrastructure, systems, networks or services have been accessed, tested, interfered or harmed in any way.

Four major deliverables have been produced throughout the internship programme Lab Environment Build Report, Connectivity & Traffic Analysis Report, Vulnerability Assessment Report (VAR) and Web Application Security Assessment Report, in addition to all relevant scan output files, screenshot evidence, and packet capture files. All deliverables are version-controlled and are submitted via the official public GitHub Repository located at github.com/Shubh21das/Maincrafts-Internship. The repository serves both as a submission platform and a cybersecurity portfolio.

Throughout the course of the internship, sufficient proficiency in the use of key cybersecurity tools and processes (Nmap, Nikto, Dirsearch, Burp Suite, Wireshark) and reporting/Version Control techniques is acquired, which can be directly applied in entry-level cybersecurity jobs (SOC Analyst Level 1, Junior Penetration Tester, Vulnerability Analyst).

1.2 Description of Maincrafts Technology



Maincrafts Technology is a technology-focused training and virtual internship organisation that designs and delivers structured, industry-relevant internship programmes for engineering students across multiple technical domains. The organisation operates with the primary objective of bridging the significant gap between academic learning and industry practice, achieving this by providing hands-on, deliverable-based programmes that simulate real professional workflows, tools, and standards.

Rather than following a passive, lecture-based approach, Maincrafts Technology's programmes are structured around weekly tasks that produce tangible, evaluable outputs — reports, scan files, screenshots, scripts, and GitHub repositories — that students can directly add to their professional portfolios. This approach ensures that graduates of the programme can demonstrate not just theoretical knowledge of cybersecurity concepts but actual, evidence-backed practical experience with the tools and processes used in real security operations.

Maincrafts Technology provides internship programmes across several technical domains, including Cybersecurity and Ethical Hacking, Artificial Intelligence and Machine Learning, Web Development, and Data Science. Each programme is tailored to develop the specific technical competencies required for relevant industry roles, ensuring that the skills developed are directly employable upon graduation.

The Cybersecurity and Ethical Hacking programme specifically is designed to reflect the scope of work performed by professionals in roles such as Junior Penetration Tester, SOC Analyst, and Vulnerability Analyst. It covers core areas including virtualisation and lab environment setup, network reconnaissance, vulnerability assessment, web application security testing, traffic analysis, and professional reporting — providing a comprehensive introduction to the practical side of cybersecurity that is rarely covered in academic curricula in sufficient depth.

1.3 Domain/Team – Cyber Security & Ethical Hacking

Cybersecurity is the process of securing systems, networks, software, data, and hardware against cyber-attacks, intrusions, damages and disruptions. Today, as businesses in all industries become more and more dependent on the digital infrastructure the stakes of such threats have increased tremendously – from data breaches leaking personal information of millions of people, to ransomware attacks halting operations of entire hospitals, government agencies and critical infrastructure.

The ethical hacking, or penetration testing, white-hat hacking is the officially, structurally and professionally authorized process of evaluating the security defenses of a computer system by simulating attacks performed by malicious actors. The goal of such exercises is finding vulnerabilities in systems, networks and applications before hackers do, thus being able to address these vulnerabilities beforehand. The ethical hacking is the legal and contractual exercise which always takes place according to defined scope and has been formally approved in writing by the owner of the computer system.

In professional practice, the penetration tester or security analyst goes through the well-defined and structured engagement lifecycle which includes the following phases:

1. Reconnaissance and Information Gathering – Gathering publicly available and actively discovered information on the target, which includes information on open ports, services and applications running and the version numbers, and available endpoints;
2. Vulnerability Scanning and Enumeration – Scanning the target using the automation tools to detect known vulnerabilities, misconfiguration, and weakness in discovered services and applications;
3. Exploitation – Actively exploiting discovered vulnerabilities to prove their existence and impact; (this phase was not in the scope of this internship programme);
4. Post-Exploitation Analysis – Evaluating what would an attacker be able to accomplish by exploiting the vulnerability, such as gaining access to administrative accounts or accessing data;
5. Reporting and Remediation – Preparing the professional Vulnerability Assessment Report including the description of all the findings, risk assessment, and recommendations to remediate vulnerabilities.

This internship included Phases 1,2,3 and 4 of the above-mentioned engagement lifecycle and gave practical experience with the tools utilized in professional penetration testing engagements. The tools covered in this internship are those used every day by security analysts and penetration tester in the industry are :

1. Kali linux
2. VirtualBox
3. Docker
4. OWASP Juice Shop
5. Nmap
6. Nikto
7. Dirsearch
8. Burp Suite CE
9. Wireshark
10. Git & GitHub

The demand for cybersecurity professionals has grown exponentially in recent years. According to industry reports, there is a global shortage of approximately 3.4 million cybersecurity professionals, making this one of the fastest-growing and most secure career domains in technology. Skills in vulnerability assessment, penetration testing, and security operations are among the most sought-after in the IT job market, with roles such as SOC Analyst, Penetration Tester, and Security Engineer consistently ranking among the highest compensated positions in the technology sector.

1.4 Lab Environment

All task-related activities in this internship were done in a personal, isolated cybersecurity lab environment based on the student's computer with open-source software. The laboratory was built from scratch in order to fulfill two main prerequisites: absolute isolation from real networks and enough power to simulate the actual attacker-target network topology in a professional penetration testing scenario.

The architecture of the lab was based on two major parts. The first one was a Kali Linux virtual machine running under Oracle VirtualBox which was used as the attacker workstation — the machine for performing reconnaissance, scanning, and security testing. The second part of the infrastructure was the OWASP Juice Shop vulnerable web application which was set up as a Docker container running inside the Kali Linux virtual machine. This was the target application for all the assessment-related activities in the internship.

The network isolation was achieved with the help of an internal bridge network of Docker which limits the network access of the target container only to the local machine. NAT adapter in the Kali virtual machine was used only to download some packages and images of Docker at the beginning of the work – it wasn't used for any scanning or testing at all.

2. INTERNSHIP DISCUSSION

2.1. Opportunity Description

The internship program has been completed as part of the Maincrafts Technology's Cybersecurity and Ethical Hacking Internship Program. The internship program has been conducted virtually for engineering students with a keen interest in cybersecurity, networking, and ethical hacking skills. The main objective of this internship program has been the development of core competencies for an entry-level role such as SOC Analyst (Level 1), Junior Penetration Tester, and Vulnerability Analyst, the positions which are always highly in demand within the technology job market.

The main focus of the programme has been the development of skill sets of a junior security analyst. Instead of offering pre-built environment and step by step tutorial on how to complete the task, the program has been designed in such a way so that structured task briefs have been offered with objectives, scope, deliverable and documentation of tools required for that task. Thus, it is up to the student to complete the task without any guidance. It is expected that the student has to find out how to do a certain task on his own, thus introducing an element of uncertainty just as a junior security analyst faces in the industry. Thus, the approach used in this program is much more useful compared to a pure tutorial approach.

The internship program has been very timely and useful for me due to the current academic and career goals of mine. Currently, I am a third year student of Computer Engineering at MIT Academy of Engineering, Pune. I am very interested in the career of cybersecurity, especially as a SOC Analyst. Therefore, this program has offered the perfect opportunity for me to gain the practical knowledge of the cybersecurity field.

2.2. Role description/statement

During this internship, the student functioned in the role of a Cybersecurity Intern / Junior Penetration Testing Analyst. The responsibilities associated with this role included:

- Independently planning, configuring, and maintaining the cybersecurity laboratory environment, including virtual machine setup, network adapter configuration, Docker engine installation, and target application deployment — reflecting the environment-setup responsibilities of a junior security analyst joining a new engagement.
- Performing structured network reconnaissance using Nmap, including host discovery, full-port TCP scanning, and service version enumeration — reflecting the pre-engagement information-gathering phase of a professional penetration test.
- Conducting automated web application vulnerability scanning using Nikto and directory enumeration using Dirsearch — reflecting the automated scanning phase of a web application security assessment.
- Performing manual web application security testing using Burp Suite as an intercepting HTTP proxy, including request interception, API surface mapping using HTTP History, manual endpoint testing using the Repeater tool, and security header analysis — reflecting the manual testing phase of a professional web application penetration test.
- Capturing and analysing packet-level network traffic using Wireshark on the loopback interface — reflecting the traffic analysis skills required for network security monitoring and incident response roles.
- Documenting all findings, evidence, and outputs in structured, professional reports including a Lab Build Report, Connectivity and Traffic Analysis Report, Vulnerability Assessment Report (VAR), and Web Application Security Assessment Report — reflecting the reporting responsibilities that are central to every professional security engagement.
- Maintaining a version-controlled GitHub repository as the submission and portfolio platform, including writing professional README documentation and organising deliverables logically — reflecting the portfolio management practices expected of an early-career cybersecurity professional.

2.3. Scope

The scope of this internship was explicitly defined by the Maincrafts Technology programme structure and remained consistent throughout all four tasks.

In Scope

- Kali Linux VM (attacker machine, all tools and activities)
- OWASP Juice Shop Docker container (port 3000)
- localhost / 127.0.0.1 (all ports)
- Passive and active scanning within the lab environment
- Web application security testing (Juice Shop only)
- Traffic capture on loopback interface only
- Professional documentation and reporting of findings

Out of Scope

- Any real-world, public-facing, or third-party systems
- Exploit attempts or active system modification
- Denial of service or destructive testing
- Social engineering or phishing simulations
- Any cloud services or externally hosted systems
- Bypassing or modifying Docker container internals
- Any testing beyond the lab boundary

2.4. Implementation

2.4.1 Task 1: Threat Intelligence Report (Awareness & Research)

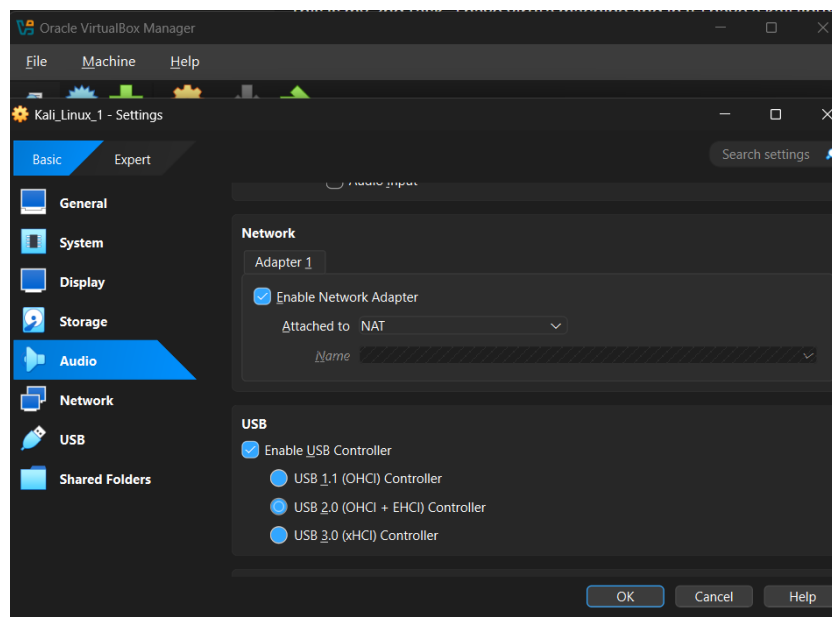
Objective: To understand the current cybersecurity threat landscape and present findings in a professional threat intelligence report format.

Work Performed:

The first task of the internship is the creation and configuration of the full lab environment of the cybersecurity laboratory from scratch. In particular, certain architectural decisions are required concerning the virtualization platform, network setup, target applications, and organization of evidence. These decisions are important for the realism, security, and applicability of the lab environment for future tasks.

Task 1 can be considered as the pre-engagement setup stage of a professional penetration testing engagement. At this stage, the testers configure the working environment, check the tools, and separate the infrastructure before starting the actual testing. Good setup ensures that there will be no scope violation problems, tooling problems, and problems with reproducing results.

VirtualBox Installation and Configuration



Zero-cost license, cross-platform compatibility, huge number of adopters, support of OVA file import and snapshots make Oracle VirtualBox the right choice for the virtualization platform.

VirtualBox was installed on the host PC with Windows 7 and Kali Linux virtual machine was configured. NAT is enabled on Adapter 1, providing the possibility to access the Internet from Kali through the host computer without exposing to the outside networks. Kali receives a private IP address from the `10.0.2.x` range which cannot be reached from the Internet directly.

Deployment and Configuration of Kali Linux VM

Kali Linux was chosen as an attacking OS for the internship. It is a Linux distribution based on Debian, developed and supported by Offensive Security.

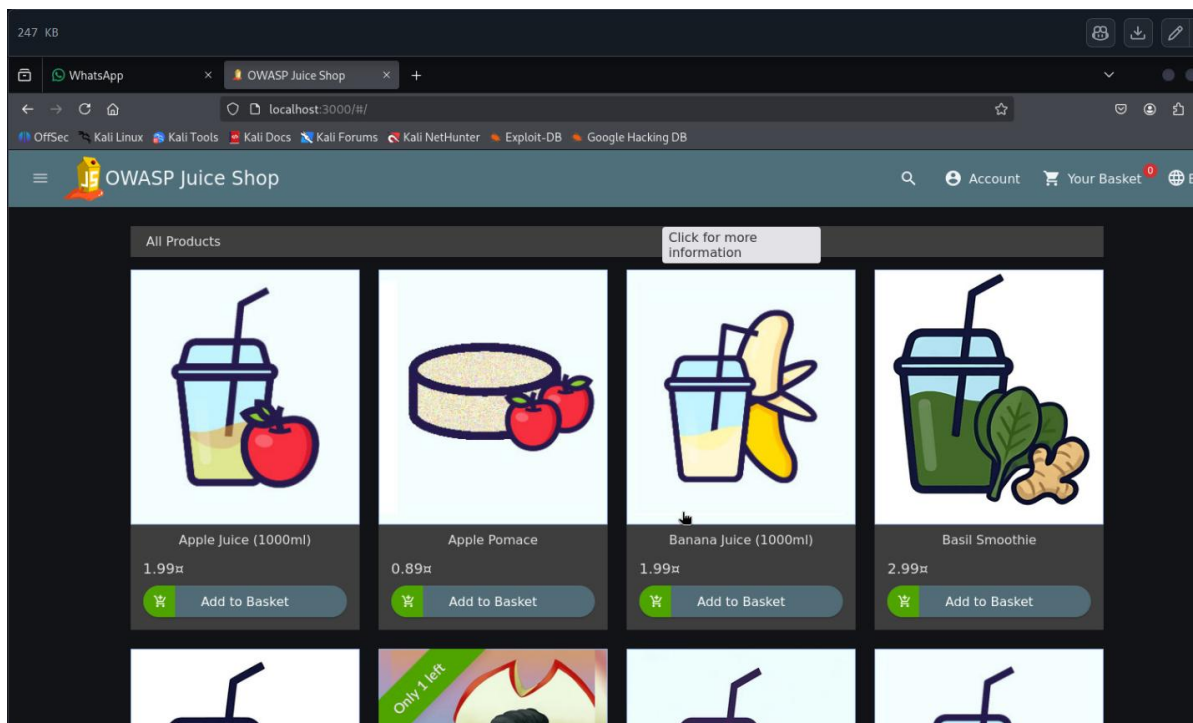
2.4.2 Task 2: Target Deployment, Connectivity Validation & Traffic Analysis

Objective: To build a safe, isolated penetration-testing environment to be used as the foundation for all subsequent hands-on tasks.

Work Performed:

Task 2 focused on deploying the target application, validating connectivity with Nmap, and analysing network traffic using Burp Suite and Wireshark. This represents the initial reconnaissance and validation phase of a penetration testing engagement.

Docker & OWASP Juice Shop Deployment



OWASP Juice Shop is an intentionally vulnerable e-commerce application maintained by the OWASP Foundation. It contains 100+ vulnerabilities, including SQL injection, XSS, broken access control, authentication weaknesses, and security misconfigurations, making it suitable for penetration-testing practice.

Docker was used for isolated and reproducible deployment. The following commands were executed:

- **sudo apt install -y docker.io – Install Docker**
- **sudo systemctl enable --now docker – Start Docker**
- **sudo docker pull bkimminich/juice-shop – Download Juice Shop**
- **sudo docker run -d -p 3000:3000 --name juice bkimminich/juice-shop – Run the application**
- **sudo docker ps – Verify deployment**

Juice Shop was made accessible on port **3000**.

Nmap Connectivity Validation

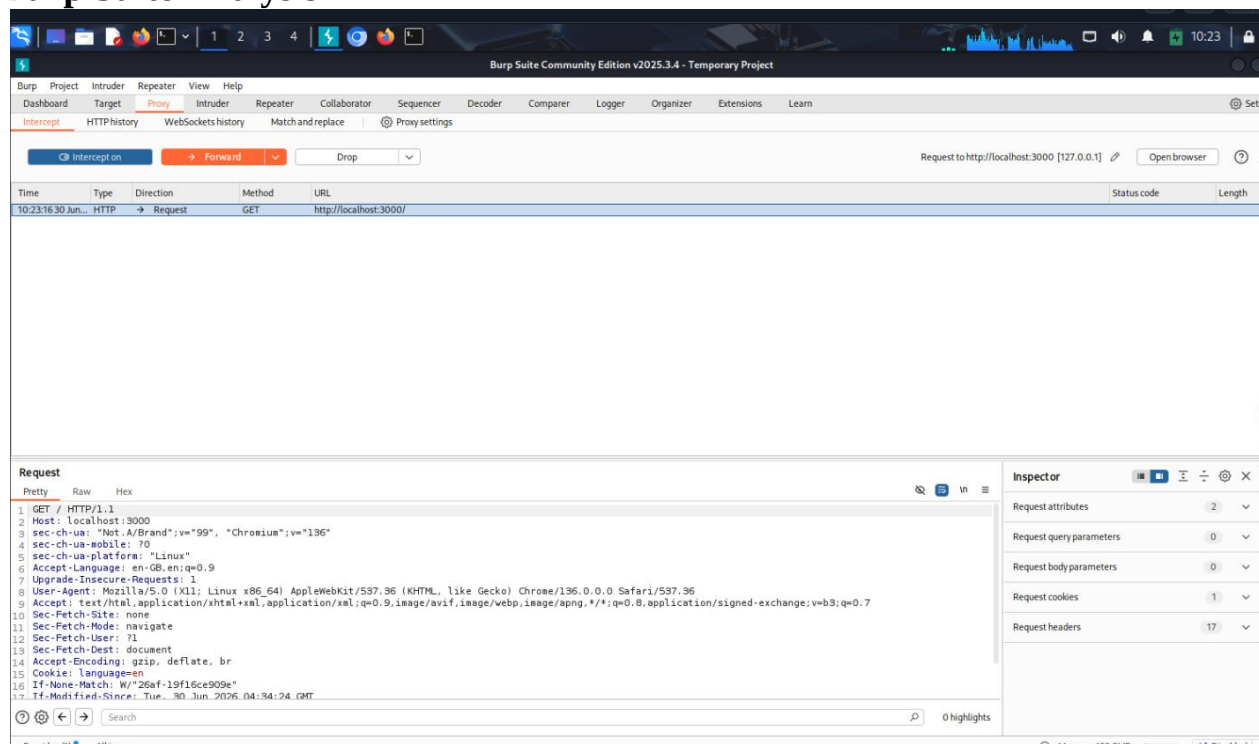
The target was tested using:

```
nmap -sV -p 3000 127.0.0.1
```

The scan confirmed that port **3000** was open and running HTTP. The response identified the application as **OWASP Juice Shop** with a 200 OK response.

Check	Result
Host	Up
Port	3000 – Open
Protocol	TCP/HTTP
Application	OWASP Juice Shop

Burp Suite Analysis



Burp Suite was configured as a proxy on 127.0.0.1:8080, with Firefox traffic routed through it. Requests to Juice Shop were intercepted and recorded in HTTP History. Key endpoints identified included product search, inventory, application configuration, application version, and Socket.IO connections. This demonstrated how Burp can be used to identify an application's API surface during reconnaissance.

Wireshark Traffic Capture

Wireshark captured traffic on the **Loopback (lo) interface** while browsing Juice Shop. The capture was saved as:

~/lab/pcaps/juice-shop-capture.pcapng

Analysis confirmed TCP handshakes, HTTP requests/responses, connection termination, and raw HTTP data. All traffic used **127.0.0.1**, confirming that communication remained local and was not externally exposed.

2.4.3 Task 3: Reconnaissance, Vulnerability Scanning & Service Enumeration

Objective: To learn how cybersecurity analysts identify weaknesses in a system before attackers do, following a professional, non-destructive assessment workflow.

Work Performed:

Task 3 was the main technical assessment phase of the internship. It involved systematic vulnerability assessment of the OWASP Juice Shop using Nmap, Nikto, and Dirsearch, following principles from the OWASP Testing Guide and PTES. Scan results were saved in ~/lab/scans and used as evidence for the vulnerability assessment report.

Step 1: Host Discovery

```
(abhishek@kali)-[~/lab/scans]
└─$ nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 19:34 IST
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.01 seconds
```

Nmap was first used to confirm that the target was reachable:

```
nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
```

The scan confirmed that 127.0.0.1 was up with very low loopback latency. The results were saved as the first assessment evidence.

Step 2: Port and Service Enumeration

```
(abhishek@kali)-[~/lab/scans]
└─$ nmap -sV -p- 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 19:34 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp   open  ppp?
43739/tcp  open  http    Golang net/http server
2 services unrecognized despite returning data. If you know the service/version,
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port3000-TCP:V=7.95%I=7%D=7/10%Time=6A50FC0F%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,2866,"HTTP/1\1\0200\200K\r\nAccess-Control-Allow-Origin:\x
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Fri,\x2010\x20Jul\x202026\x2014:03:52\x20GMT\r\nE
SF:Tag:\x20W/\x20"26af-19f4c5785d7"\r\nContent-Type:\x20text/html;\x20chase
SF:t=UTF-8\r\nContent-Length:\x200002\r\nVary:\x20Accept-Encoding\r\nDate:
```

A full TCP port and service scan was performed:

nmap -sV -p- 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt

The scan checked all 65,535 TCP ports and used service detection to identify applications. Only port 3000 was open, running HTTP and confirmed as OWASP Juice Shop.

Step 3: Web Vulnerability Scanning with Nikto

```
+ Target IP:      127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port:    3000
+ Platform:       Unknown
+ Start Time:     2026-07-10 19:36:06 (GMT5.5)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://develop
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mo
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://devel
+ [013587] /: Suggested security header missing: content-security-policy. See: https://develop
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozil
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
```

Nikto was used to identify common web-server security issues:

nikto -h http://127.0.0.1:3000 -o ~/lab/scans/nikto.txt

The complete Nikto report was saved to ~/lab/scans/nikto.txt.

Step 4: Directory and Endpoint Enumeration

```
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 5 | Wordlist size: 11460
Output File: /home/shubh/lab/scans/dirsearch.txt
Target: http://127.0.0.1:3000/

[19:50:16] Starting:
[19:50:43] 200 - 475B - /.well-known/security.txt
[19:51:36] 500 - 2KB - /api
[19:51:37] 301 - 158B - /api-docs → /api-docs/
[19:51:37] 500 - 2KB - /api-doc
[19:51:37] 500 - 2KB - /api.php
[19:51:37] 500 - 2KB - /api.log
[19:51:37] 500 - 2KB - /api/
[19:51:37] 500 - 2KB - /api.py
[19:51:37] 500 - 2KB - /api/2/explore/
[19:51:37] 500 - 2KB - /api/_swagger_/
[19:51:37] 500 - 2KB - /api/2/issue/createmeta
[19:51:37] 500 - 2KB - /api/api
[19:51:37] 500 - 2KB - /api/_swagger_/
[19:51:37] 500 - 2KB - /api/apidocs
[19:51:37] 500 - 2KB - /api/api-docs
[19:51:37] 500 - 2KB - /api/apidocs/swagger.json
[19:51:37] 500 - 2KB - /api/batch
[19:51:37] 500 - 2KB - /api/application.wadl
[19:51:37] 500 - 2KB - /api/config
[19:51:37] 500 - 2KB - /api/cask/graphql
[19:51:37] 500 - 2KB - /api/docs
[19:51:37] 500 - 2KB - /api/docs/
[19:51:37] 500 - 2KB - /api/index.html
[19:51:37] 500 - 2KB - /api/error_log
[19:51:37] 500 - 2KB - /api/jsonws
[19:51:37] 500 - 2KB - /api/jsonws/invoke
```

Dirsearch was used to discover hidden directories and endpoints:

- **dirsearch -u http://127.0.0.1:3000 -t 5 -o ~/lab/scans/dirsearch.txt**

Important endpoints discovered included /api, /rest, /api/Quantities, /socket.io, /assets, and /ftp. Most significantly, /rest/admin/application-configuration was accessible without authentication, representing the most critical finding of the assessment. The results were saved to ~/lab/scans/dirsearch.txt

2.4.4 Task 4: Exploitation & Web Application Security Testing

Objective: To move from identification to controlled, ethical exploitation of the vulnerabilities discovered in Task 3, strictly within the lab environment (DVWA, OWASP Juice Shop, Metasploitable2 only).

Work Performed:

Task 4 was the phase for conducting manual security assessments. In Burp Suite, the Juice Shop application was tested against key security risks from OWASP Top 10. Information gathered in Tasks 2-4 was put together to create a Vulnerability Assessment Report (VAR).

Manual Security Testing of API

With the use of Burp Suite Repeater, API requests discovered in prior reconnaissance were modified and sent. The tests conducted included the following:

- Authentication bypass: /rest/admin/application-configuration and /rest/admin/application-version returned 200 OK without authentication. It proves broken access control and leakage of administrative information.
- HTTP Methods Testing: OPTIONS requests revealed that some endpoints support such methods as GET, POST, PUT, PATCH and DELETE. It increases the risk of unauthorized modification of the data.
- Security headers: the absence of such security headers as CSP, X-Frame-Options, X-Content-Type-Options, HSTS, Referrer-Policy, Permissions-Policy was detected.
- Input reflection: the /rest/products/search?q= endpoint reflects the user input in the JSON response. It indicates a possible injection vulnerability

to be verified further.

- **Application version disclosure:** the application-version endpoint discloses the exact Juice Shop version. It can be helpful for attackers to know about existing vulnerabilities.

Vulnerability Assessment Report

All information found was presented in a professional report with risk ratings based on CVSS. The findings include the following:

- **Critical:** unauthenticated administrative API endpoints.
- **High:** missing CSP, unauthenticated REST API access and HTTPS/TLS.
- **Medium:** application version disclosure, missing X-Frame-Options and unsupported HTTP methods.
- **Low:** missing X-Content-Type-Options.

Remediation

Possible solutions are: implement authentication and RBAC for administrative APIs, protect REST API endpoints by using authentication, enable HTTPS/TLS and HSTS, add security headers like CSP and X-Frame-Options, limit HTTP methods usage, hide the application version and add **X-Content-Type-Options: nosniff**.

2.5 Tools/Technologies Used Regularly

1. **Kali Linux** : primary attacker operating system for all penetration testing activities.
2. **VirtualBox** : virtualization platform used to build and isolate the lab environment (attacker + target VMs).
3. **OWASP Juice Shop & DVWA** : intentionally vulnerable applications used as safe, legal targets for practicing web application security testing.
4. **Nmap** : used for host discovery, port scanning, and service/version enumeration.
5. **Nikto** : used to identify web server misconfigurations and outdated components.
6. **Dirsearch** : used for discovering hidden directories, files, and admin panels.
7. **Burp Suite (Community Edition)** : used for intercepting, analyzing, and modifying HTTP requests during manual web application testing.
8. **Docker** : used to deploy the OWASP Juice Shop target application in a containerized environment.
9. **OWASP Top 10 framework** : used as the reference standard for classifying and understanding web application vulnerabilities.
10. **Wireshark** : Network protocol analyser. Used for packet-level capture and analysis of TCP/HTTP traffic on the loopback interface.

2.6 Most Challenging Tasks Performed

Several technical challenges were encountered during the internship that required independent troubleshooting, research, and practical problem-solving. The three major challenges are described below.

1. Challenge 1 – apt Package Lock Conflict During Docker Installation

During Task 1, the apt upgrade process was accidentally suspended using Ctrl+Z. This left the process running in the background while still holding the dpkg lock, causing Docker installation to fail with a cache-lock error.

The issue was diagnosed using `ps aux | grep apt` and `jobs`, which confirmed that the original apt process was still active. The process was brought back to the foreground using `fg %1` and then terminated with Ctrl+C, which released the package manager lock. Docker was then installed successfully.

Learning: This challenge improved understanding of Linux process management and the difference between Ctrl+Z for suspending a process and Ctrl+C for interrupting it.

2. Challenge 2 – Building the Isolated Lab Environment:

Building the Isolated Lab Environment: As someone new to virtualization and network segmentation, configuring the dual network adapters (NAT for internet access and Host-Only for isolated lab traffic) correctly, without exposing the vulnerable target application to the internet, was initially challenging. Understanding subnetting and confirming proper isolation using Nmap host discovery required careful, methodical troubleshooting.

3 LEARNING OUTCOMES

3.4 Technical Skills Acquired

The 6-week internship provided practical experience in cybersecurity, ethical hacking, and security operations. The major skills developed are:

- **Virtualisation and Lab Management:**
Gained experience with VirtualBox, including OVA import, CPU/RAM allocation, network configuration, snapshots, and VM troubleshooting.
- **Docker and Containerisation:**
Learned to deploy and manage Docker containers, including image pulling, port mapping, container lifecycle management, status checks, and log analysis.
- **Network Reconnaissance with Nmap:**
Developed skills in host discovery, full-port scanning, service/version detection, banner analysis, and saving scan results for reporting.
- **Web Vulnerability Scanning with Nikto:**
Gained practical experience scanning web applications and identifying security issues such as missing security headers and insecure configurations.
- **Directory Enumeration with Dirsearch:**
Learned to discover hidden directories and API endpoints using wordlists and assess their potential security significance.
- **Web Application Testing with Burp Suite:**
Developed practical skills using Proxy, Intercept, HTTP History, and Repeater to capture, analyse, modify, and replay HTTP requests.
- **Packet Analysis with Wireshark:**
Gained experience capturing and analysing network traffic, interpreting TCP packets and flags, and examining HTTP application-layer data.
- **Vulnerability Assessment Reporting:**
Learned to prepare professional security reports containing findings, evidence, CVSS-based risk ratings, impact analysis, and remediation recommendations.

- **Git and GitHub:**
Developed skills in repository management, staging, committing, pushing changes, and maintaining an organised cybersecurity portfolio.
- **Linux Command-Line Proficiency:**
Strengthened Kali Linux skills in process management, file operations, networking, package and service management, and Docker CLI usage.

3.5 Managerial/Soft Skills Acquired

- **Technical Documentation and Report Writing:**
Acquired the skill of presenting technical results in a clear and concise manner via formal reports to technical and non-technical audiences.
- **Independent Problem-Solving:**
Enhanced the skill of identifying technical problems, researching possible reasons for these problems, testing the solution and resolving the problem independently from any predefined solution.
- **Time Management:**
Enhanced the skill of performing multiple activities at the same time during security testing, evidence collection, report writing, and other deliverables maintenance.
- **Ethical Discipline and Scope Compliance:**
Improved the skill of demonstrating professionalism in verifying the testing scope and adhering to all required ethical and authorised limits.
- **Attention to Details:**
Improved the skill of systematic analysis when scanning scan results, HTTP responses, endpoints, security results in order to not overlook any vulnerability.
- **Professional Portfolio Maintenance:**
Acquired experience in maintaining the structured portfolio in GitHub with all required documentation and commit practice.

3.6 Problem-Solving & Critical Thinking

- **Root Cause Analysis:**
Learned how to identify the real reason behind the technical problem and then apply the solution to it, such as identifying the dpkg lock problem before removing the file lock.
 - **Risk-based Approach in Decision Making:**
Learned how to choose the less disruptive solution first, such as lowering the number of Dirsearch threads before choosing an alternative tool.
 - **Critical Analysis of Results Produced by Tools:**
Learned how to distinguish the most critical vulnerabilities from lower risk vulnerabilities and other informational results of the security scan.
 - **Attacker and Defender Perspective:**
Learned how to consider both ways of exploiting a vulnerability and how to fix it.
 - **Risk Assessment in the Context:**
Improved the skill of assessing the vulnerability based on its importance in relation to the application purpose, data sensitivity, potential impact and other security aspects.
-

4 LEARNING OUTCOMES

4.4 Conclusion

The Summer Internship Programme at Maincrafts Technology has proven to be a truly outstanding and professional experience which has contributed greatly to both the technical skills and professional development of the student. Over the course of six weeks and four progressive tasks, the internship has provided direct exposure to all phases of a professional vulnerability assessment process – starting from the creation of the environment and ending with the professional documentation of findings including risk assessment and remediation recommendations.

Task 1 was dedicated to setting up the basic infrastructure of the isolated Kali Linux laboratory with the use of Docker for deployment of the target application and GitHub for the version control of the code – and has provided the understanding of the professional process of environment configuration.

Task 2 covered validation of the set-up lab by means of connectivity testing with Nmap, set up of the HTTP traffic analysis infrastructure with the use of Burp Suite, and generation of the packet level network traffic capture using Wireshark.

Task 3 was the main technical task of the internship and included the process of reconnaissance consisting of host discovery, full port enumeration, scanning of the application for vulnerabilities with the use of Nikto and directory enumeration with the use of Dirsearch tool.

Task 4 involved the process of vulnerability exploitation and validation by the means of web application security testing with Burp Suite Repeater, resulting in a professional Vulnerability Assessment Report with the description of eight findings, including Critical, High, Medium, and Low severity – each with its own evidence and remediation recommendation.

The programme has resulted in a portfolio of professional and evidenced

deliverables – four formal reports, all scan output files, a packet capture made in Wireshark, and a properly organized publicly accessible GitHub repository – which demonstrates the true level of cyber-security competence of the student. All the skills learned, all the findings documented and all the challenges solved during the internship are directly related to the tasks performed in the cybersecurity field as part of one's work. Tools used as part of the process – Nmap, Nikto, Dirsearch, Burp Suite, and Wireshark – are not simply a theoretical academic knowledge, but a set of tools used everyday by professionals in real world security assessments.

4.5 Future Scope

Based on the knowledge and practical experience gained during the internship, the following areas have been identified for further development:

1. **CEH and CompTIA Security+**
Pursue CEH and Security+ certifications to validate cybersecurity knowledge and strengthen employability for security analyst and penetration testing roles.
2. **Practical Penetration Testing Certifications**
Work toward hands-on certifications such as eJPT and PNPT to improve practical penetration testing and reporting skills.
3. **OWASP Juice Shop Exploitation**
Extend the current lab work by safely exploiting identified vulnerabilities such as SQL injection, XSS, broken access control, and IDOR.
4. **SIEM and SOC Tools**
Develop practical skills with Splunk and Wazuh, focusing on log analysis, alert monitoring, and incident detection for SOC roles.
5. **Python for Security Automation**
Improve Python skills for automating scan analysis, report generation, security tools, and basic network scanning tasks.
6. **CTF Competitions**
Regularly participate in platforms such as Hack The Box, TryHackMe, and PicoCTF to strengthen practical skills across different cybersecurity domains.
7. **PortSwigger Web Security Academy**
Complete hands-on labs covering major web vulnerabilities such as SQL injection, XSS, CSRF, SSRF, and access control.
8. **Cloud Security – AWS**
Build foundational AWS security knowledge, including IAM, GuardDuty, CloudTrail, Security Hub, and VPC security controls.

5 REFERENCES

- [1] OWASP Foundation, "OWASP Juice Shop Project," OWASP. Available at: <https://owasp.org/www-project-juice-shop/>
- [2] OWASP Foundation, "OWASP Top Ten 2021," OWASP. Available at: <https://owasp.org/www-project-top-ten/>
- [3] OWASP Foundation, "OWASP Testing Guide v4.2," OWASP. Available at: <https://owasp.org/www-project-web-security-testing-guide/>
- [4] Nmap Project, "Nmap Reference Guide," Nmap.org. Available at: <https://nmap.org/book/man.html>
- [5] Nmap Project, "Nmap Network Scanning – The Official Nmap Project Guide to the Network Mapper," Gordon Lyon (Fyodor). Available at: <https://nmap.org/book/>
- [6] CIRT.net, "Nikto2 Web Server Scanner – Documentation," CIRT. Available at: <https://cirt.net/Nikto2>
- [7] Maurodoria, "Dirsearch – Web Path Scanner," GitHub Repository. Available at: <https://github.com/maurodoria/dirsearch>
- [8] PortSwigger, "Burp Suite Community Edition Documentation," PortSwigger Ltd. Available at: <https://portswigger.net/burp/documentation/desktop>
- [9] PortSwigger, "Web Security Academy – Learning Resources," PortSwigger Ltd. Available at: <https://portswigger.net/web-security>
- [10] Wireshark Foundation, "Wireshark User's Guide," Wireshark. Available at: https://www.wireshark.org/docs/wsug_html_chunked/
- [11] Docker Inc., "Docker Engine Documentation," Docker. Available at: <https://docs.docker.com/engine/>
- [12] Offensive Security, "Kali Linux Official Documentation," Offensive Security. Available at: <https://www.kali.org/docs/>

[13] FIRST.org, "Common Vulnerability Scoring System (CVSS) v3.1 Specification Document," FIRST. Available at: <https://www.first.org/cvss/specification-document>

[14] Penetration Testing Execution Standard, "PTES Technical Guidelines," PTES. Available at: <http://www.pentest-standard.org/>

[15] Maincrafts Technology, "Internship Task Briefs and Programme Structure Documentation," Internal Programme Resources. Available at: <https://www.maincrafts.com/>

[16] GitHub Inc., "GitHub Documentation – Getting Started with Git," GitHub. Available at: <https://docs.github.com/>

[17] National Institute of Standards and Technology (NIST), "National Vulnerability Database (NVD)," NIST. Available at: <https://nvd.nist.gov/>

[18] Mozilla Developer Network, "HTTP Security Headers – Web Security Reference," MDN Web Docs, Mozilla. Available at: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers>